CS 3002 Information Security

1. Explain key concepts of information security such as design principles, cryptography, risk management,(1)

2. Discuss legal, ethical, and professional issues in information security (6)
3. Analyze real world scenarios, model them using security measures, and apply various security and risk management tools for achieving information security and privacy (2)
4. Identify appropriate techniques to tackle and solve problems of real life in the discipline of information security (3)
5. Understand issues related to ethics in the field of information security(8)

Fall 2026



ISO/IEC 27001: 2013

Week # 4 – Lecture # 10, 11,12

2.4 DIGITAL SIGNATURES AND KEY MANAGEMENT

As mentioned in Section 2.3, public-key algorithms are used in a variety of applications. In broad terms, these applications fall into two categories: digital signatures, and various techniques to do with key management and distribution.

With respect to key management and distribution, there are at least three distinct aspects to the use of public-key encryption in this regard:

- The secure distribution of public keys
- The use of public-key encryption to distribute secret keys
- The use of public-key encryption to create temporary keys for message encryption

Digital Signature

Public-key encryption can be used for authentication with a technique known as the digital signature. NIST FIPS PUB 186-4 [*Digital Signature Standard (DSS)*, July 2013] defines a digital signature as follows: The result of a cryptographic transformation of data that, when properly implemented, provides a mechanism for verifying origin authentication, data integrity and signatory non-repudiation.

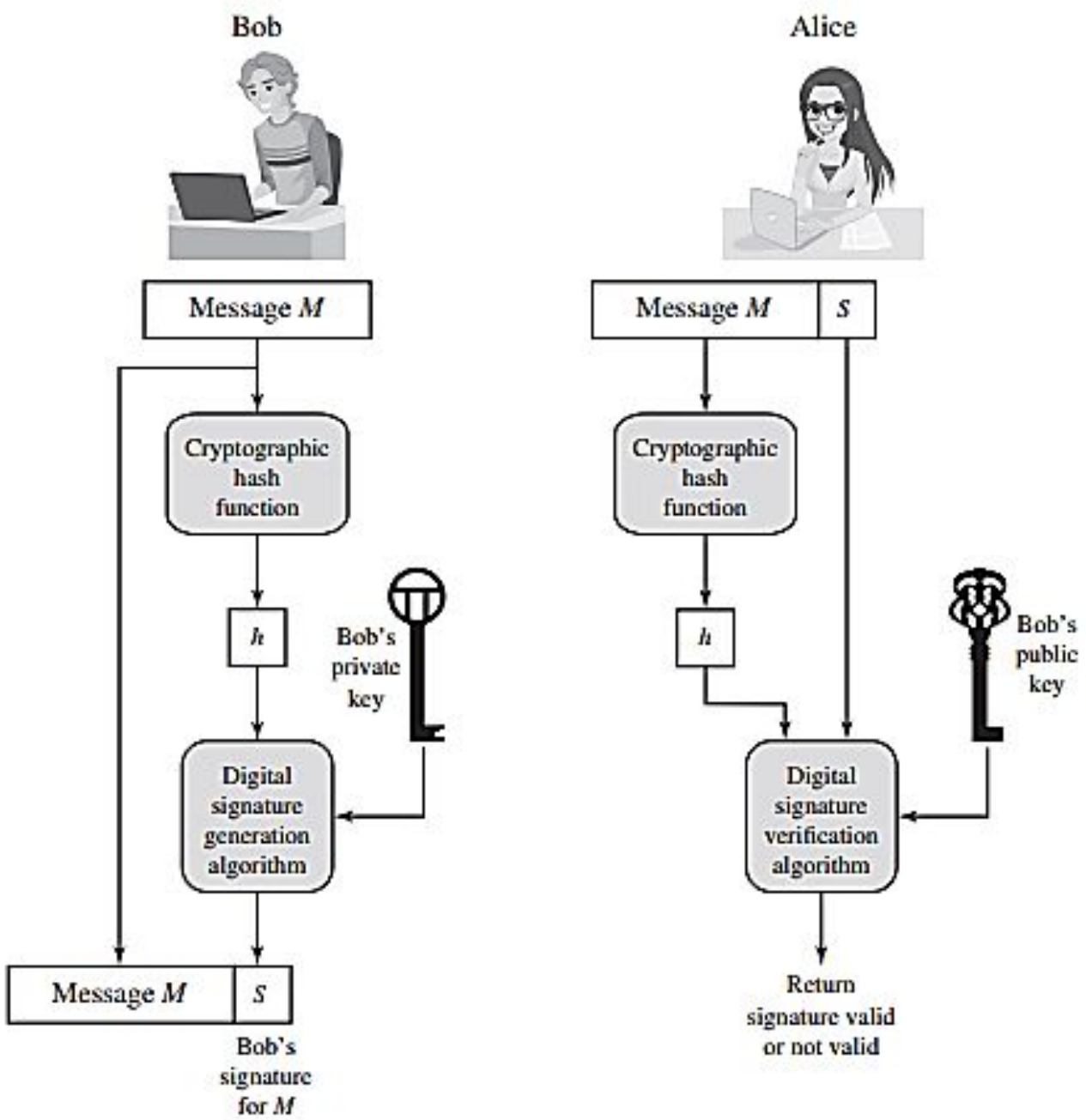
Thus, a digital signature is a data-dependent bit pattern, generated by an agent as a function of a file, message, or other form of data block. Another agent can access the data block and its associated signature and verify (1) the data block has been signed by the alleged signer, and (2) the data block has not been altered since the signing. Further, the signer cannot repudiate the signature.

Digital Signature

FIPS 186-4 specifies the use of one of three digital signature algorithms:

- **Digital Signature Algorithm (DSA):** The original NIST-approved algorithm, which is based on the difficulty of computing discrete logarithms.
- **RSA Digital Signature Algorithm:** Based on the RSA public-key algorithm.
- **Elliptic Curve Digital Signature Algorithm (ECDSA):** Based on elliptic-curve cryptography.

Digital Signature



(a) Bob signs a message

(b) Alice verifies the signature

Figure 2.7 **Simplified Depiction of Essential Elements of Digital Signature Process**

Public-Key Certificates

of the public key.

Anyone can forge public announcement. That is, some user could pretend to be Bob and send a public key to another participant or broadcast such a public key. Until such time as Bob discovers the forgery and alerts other participants, the forger is able to read all encrypted messages intended for Bob and can use the forged keys for authentication.

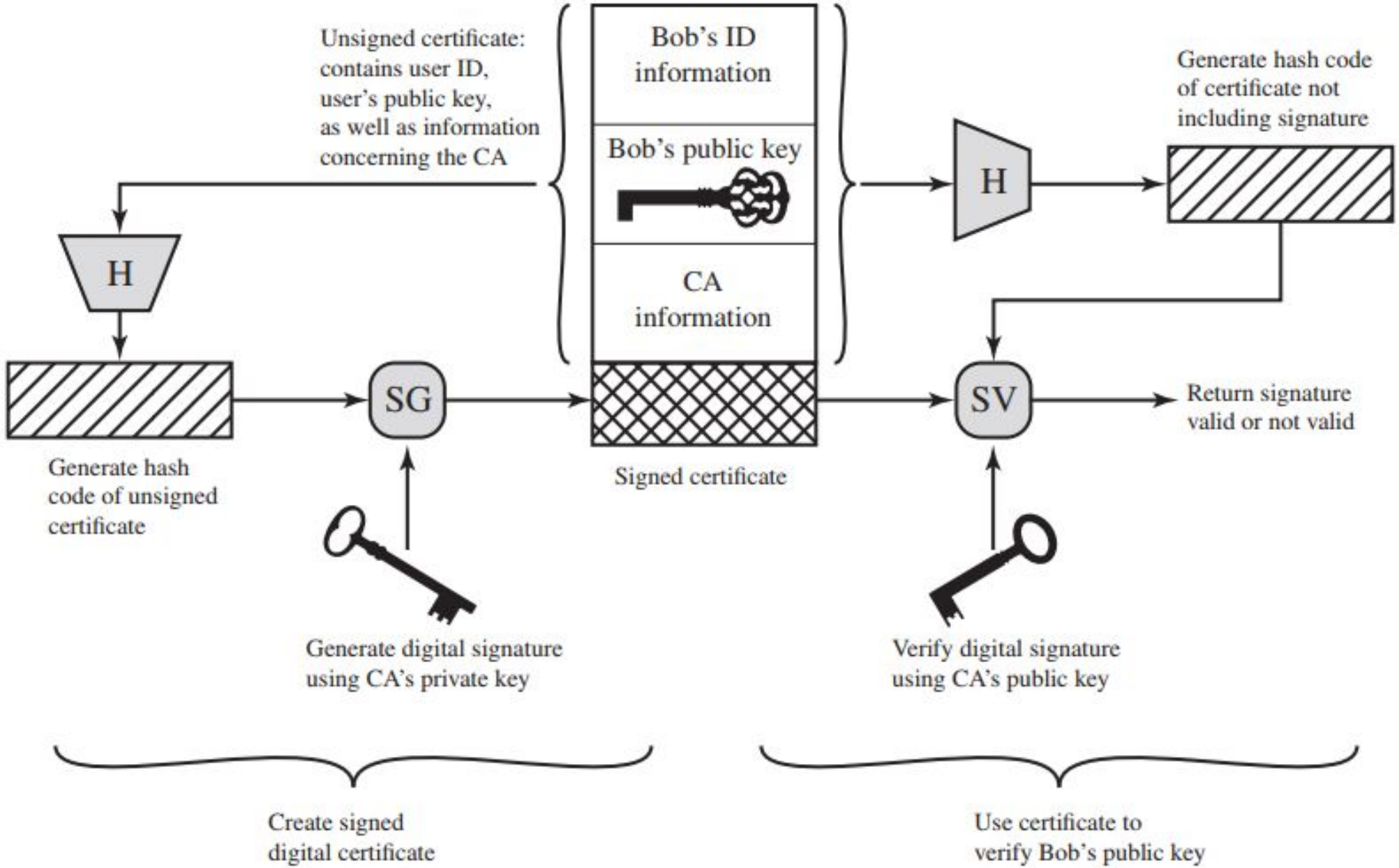


Figure 2.8 Public-Key Certificate Use

Public-Key Certificates

The key steps can be summarized as follows:

1. User software (client) creates a pair of keys: one public and one private.
2. Client prepares an unsigned certificate that includes the user ID and user's public key.
3. User provides the unsigned certificate to a CA in some secure manner. This might require a face-to-face meeting, the use of registered e-mail, or happen via a Web form with e-mail verification.
4. CA creates a signature as follows:
   a. CA uses a hash function to calculate the hash code of the unsigned certificate. A hash function is one that maps a variable-length data block or message into a fixed-length value called a hash code, such as SHA family that we will discuss in Sections 2.2 and 21.1.
   b. CA generates digital signature using the CA's private key and a signature generation algorithm.
5. CA attaches the signature to the unsigned certificate to create a signed certificate.
6. CA returns the signed certificate to client.
7. Client may provide the signed certificate to any other user.
8. Any user may verify that the certificate is valid as follows:
   a. User calculates the hash code of certificate (not including signature).
   b. User verifies digital signature using CA's public key and the signature verification algorithm. The algorithm returns a result of either signature valid or invalid.

2.7 KEY TERMS, REVIEW QUESTIONS, AND PROBLEMS

Key Terms

Advanced Encryption Standard (AES)	collision resistant	Decryption
asymmetric encryption	confidentiality	Diffie–Hellman key exchange
authentication	cryptanalysis	digital signature
brute-force attack	Data Encryption Standard (DES)	Digital Signature Standard (DSS)
ciphertext	data integrity	elliptic curve cryptography
encryption	preimage resistant	second preimage resistant
hash function	private key	secret key
keystream	pseudorandom number	secure hash algorithm (SHA)
message authentication	public key	secure hash function
message authentication code (MAC)	public-key certificate	strong collision resistant
modes of operation	public-key encryption	symmetric encryption
one-way hash function	random number	triple DES
plaintext	RSA	weak collision resistant

CHAPTER 3

USER AUTHENTICATION

3.1 **Digital User Authentication Principles**
- A Model for Digital User Authentication
- Means of Authentication
- Risk Assessment for User Authentication

3.2 **Password-Based Authentication**
- The Vulnerability of Passwords
- The Use of Hashed Passwords
- Password Cracking of User-Chosen Passwords
- Password File Access Control
- Password Selection Strategies

3.3 **Token-Based Authentication**
- Memory Cards
- Smart Cards
- Electronic Identify Cards

3.4 **Biometric Authentication**
- Physical Characteristics Used in Biometric Applications
- Operation of a Biometric Authentication System
- Biometric Accuracy

3.5 **Remote User Authentication**
- Password Protocol
- Token Protocol
- Static Biometric Protocol
- Dynamic Biometric Protocol

3.6 **Security Issues for User Authentication**

LEARNING OBJECTIVES

After studying this chapter, you should be able to:

- Discuss the four general means of authenticating a user's identity.
- Explain the mechanism by which hashed passwords are used for us authentication.
- Understand the use of the Bloom filter in password management.
- Present an overview of token-based user authentication.
- Discuss the issues involved and the approaches for remote user authentication.
- Summarize some of the key security issues for user authentication.

User Authentication

- User authentication is a fundamental security building block
- User authentication is the basis for:
  - **Access control** and **User accountability**
- User authentication encompasses two functions
  1. **Identification:**
     - The user identifies herself to the system by presenting a credential
       - such as user ID.
  2. **Verification:**
     - The system verifies the user by the exchange of authentication information.
- User Authentication is distinct from message authentication
  - (when communicating parties are concerned with the integrity of the exchanges messages)

- ***Identification*** *means by which a user provides a claimed identity to the system*
- ***User authentication*** *means of establishing the validity of the claim*

Table 3.1 **Identification and Authentication Security Requirements (NIST SP 800-171)**

	Basic Security Requirements:
1	Identify information system users, processes acting on behalf of users, or devices.
2	Authenticate (or verify) the identities of those users, processes, or devices, as a prerequisite to allowing access to organizational information systems.
	Derived Security Requirements:
3	Use multifactor authentication for local and network access to privileged accounts and for network access to non-privileged accounts.
4	Employ replay-resistant authentication mechanisms for network access to privileged and non-privileged accounts.
5	Prevent reuse of identifiers for a defined period.
6	Disable identifiers after a defined period of inactivity.
7	Enforce a minimum password complexity and change of characters when new passwords are created.
8	Prohibit password reuse for a specified number of generations.
9	Allow temporary password use for system logons with an immediate change to a permanent password.
10	Store and transmit only cryptographically-protected passwords.
11	Obscure feedback of authentication information.

3.1 DIGITAL USER AUTHENTICATION PRINCIPLES

- *NIST SP 800-63-3 (Digital Authentication Guideline, October 2016)* ***defines digital user authentication as the process of establishing confidence in user identities that are presented electronically to an information system.***
  - Systems can use the authenticated identity to determine if the authenticated individual is authorized to perform particular function such as database transactions or access to system resources.

A Model for Digital User Authentication

- The NIST SP 800-63-2 model
  - The initial requirement for performing user authentication is that the user must be registered with the system.
  - An applicant applies to a **registration authority (RA)** to become a **subscriber** of a **credential service provider (CSP)**.
    - **RA** is a trusted entity that establishes and vouches for the identity of an applicant to a CSP.
    - The **CSP** then engages in an exchange with the subscriber. The CSP issues some sort of electronic credential to the subscriber. The credential (a data structure) binds an identity to a token possessed by the subscriber
  - The party to be authenticated is called a **claimant**
  - The party verifying that identity is called a **verifier**
  - The verifier passes on an assertion about the identity of the subscriber to the **relying party (RP)**.
    - The **RP** can use the authenticated information provided by the verifier to make access control or authorization decisions.

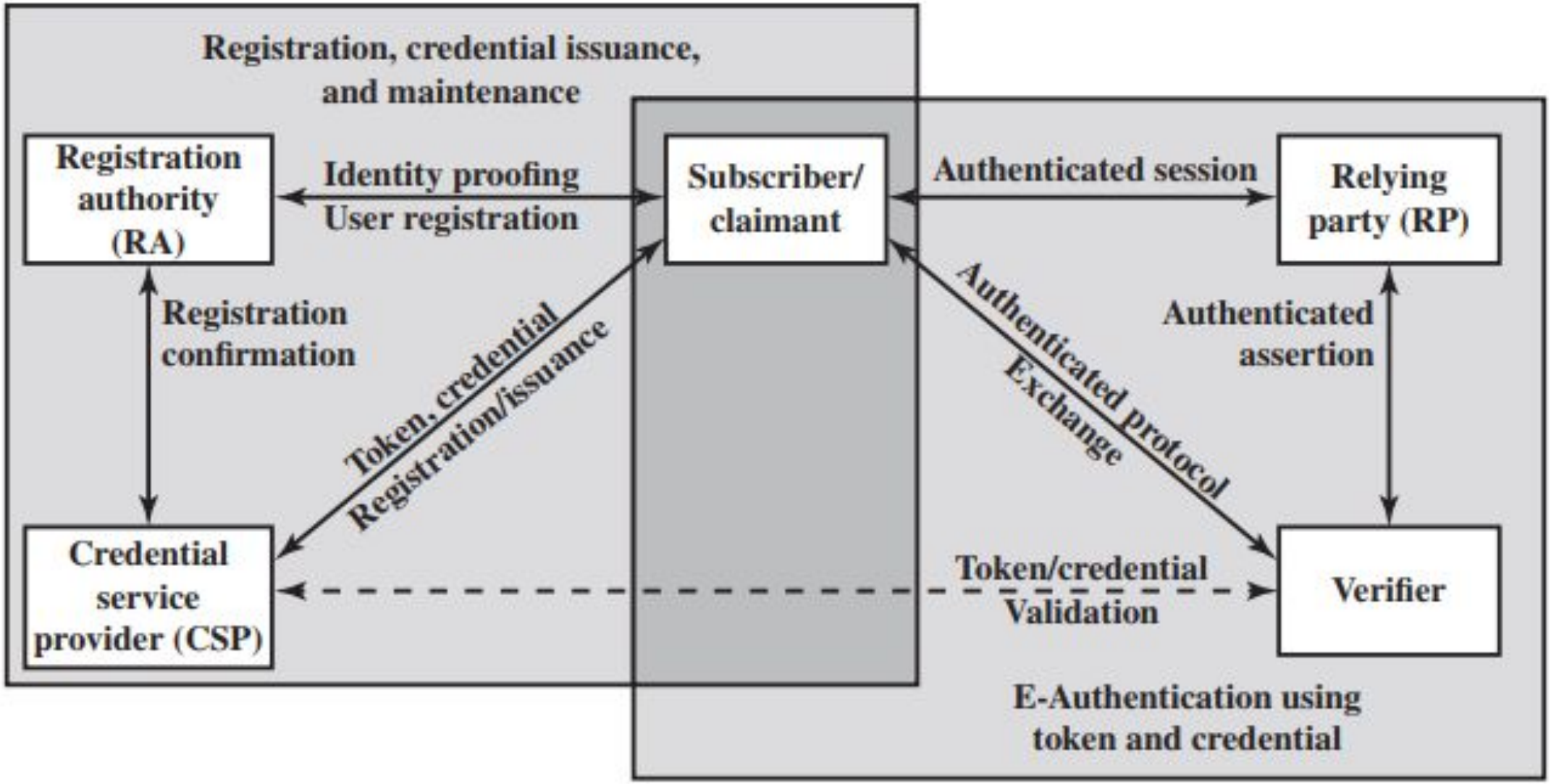


Figure 3.1 **The NIST SP 800-63-3 E-Authentication Architectural Model**

Means of Authentication

There are four general means of authenticating a user's identity, which can be used alone or in combination:

- **Something the individual knows:** Examples include a password, a personal identification number (PIN), or answers to a prearranged set of questions.
- **Something the individual possesses:** Examples include electronic keycards, smart cards, and physical keys. This type of authenticator is referred to as a *token*.
- **Something the individual is (static biometrics):** Examples include recognition by fingerprint, retina, and face.
- **Something the individual does (dynamic biometrics):** Examples include recognition by voice pattern, handwriting characteristics, and typing rhythm.

Multifactor authentication refers to the use of more than one of the authentication means in the preceding list. Implementations that use two factors are considered to be stronger than those that use only one factor; systems that incorporate three factors are stronger than systems that only incorporate two of the factors, and so on.

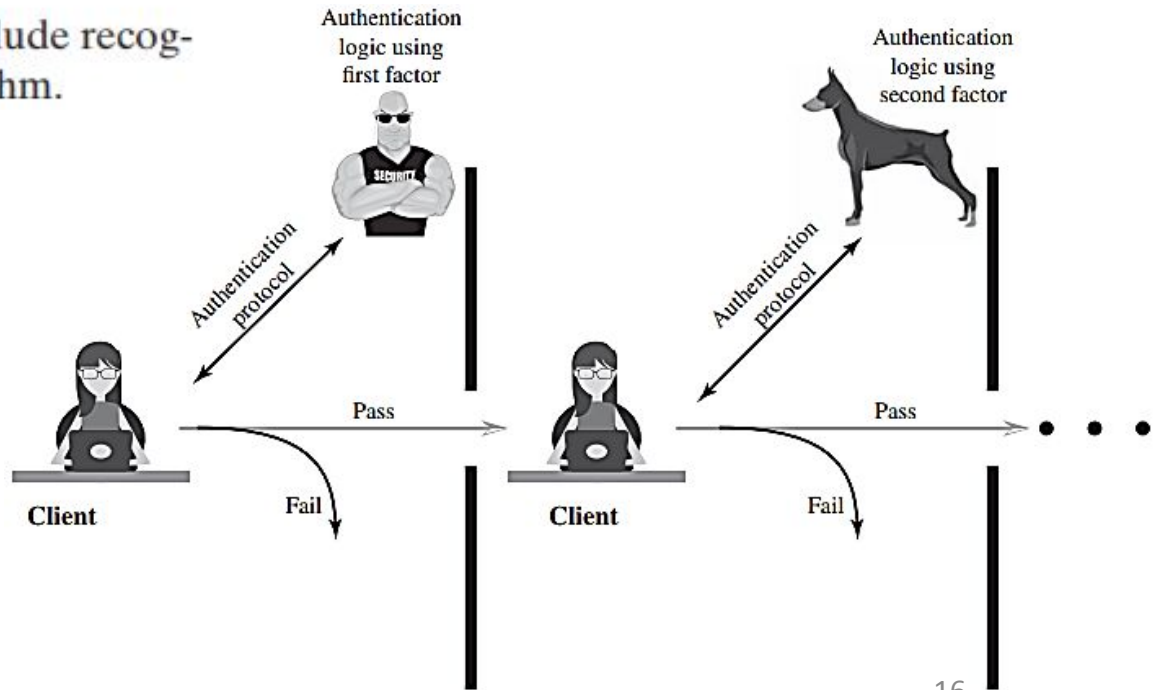


Figure 3.2 **Multifactor Authentication**